Mr_小白 Lv2
2018年08月16日 阅读 2671

关注

Java安全：SecurityManager与AccessController

前言

什么是安全?

- 程序不能恶意破坏用户计算机的环境，比如特洛伊木马等可自我进行复制的恶意程序。
- 程序不可获取主机及其所在网络的私密信息。
- 程序的提供者和使用者的身份需要通过特殊验证。
- 程序所涉及的数据在传输、持久化后都应是被加密的。
- 程序的操作有相关规则限制，并且不能耗费过多的系统资源。

保护计算机上的信息不被非法获取和修改时Java最初的，也是最基本的设计目标，但同时还要保证Java程序在主机上的运行不受影响。

Java安全方面的支持

JDK本身提供了基本的安全方面的功能，比如可配置的安全策略、生成消息摘要、生成数字签名等等。同时，Java也有一些扩展程序，更加全面地支撑了整个安全体系。

Java加密扩展包(JCE)提供了密码、安全密钥交换、安全消息摘要、密钥管理系统等功能。

Java安全套接字扩展包(JSSE)提供了SSL(安全套接字层)的加密功能，保证了与SSL服务器或SSL客户的通信安全。

Java鉴别与授权服务(JAAS)可以在Java平台上提供用户鉴别，并且允许开发者根据用户提供的鉴别信任状准许或拒绝用户对程序的访问。

一、Java沙箱

首页 搜索掘金 登录 注册

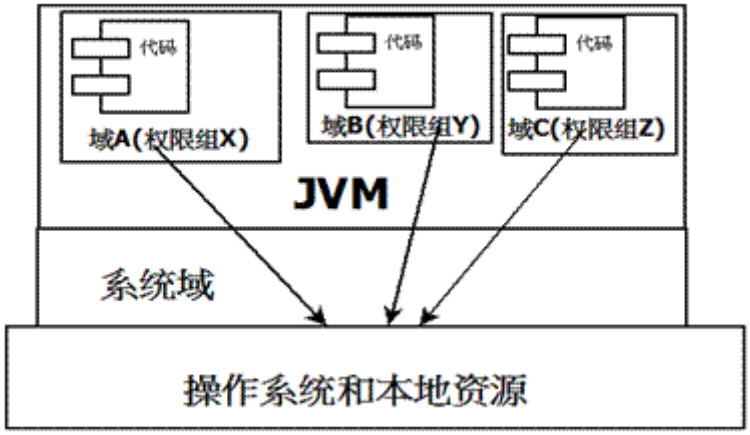
玩耍且不会受伤，同时还要保证你女朋友新买的化妆镜不会被孩子打碎。

Java沙箱负责保护一些系统资源，而且保护级别是不同的。

- 内部资源，如本地内存；
- 外部资源，如访问其文件系统或是在同一局域网的其他机器；
- 对于运行的组件（applet），可以访问其web服务器；
- 主机通过网络传输到磁盘的数据流。

一般来讲，沙箱的默认状态允许其中的程序访问CPU、内存等资源，以及其上装在的Web服务器。若沙箱完全开放，则其中程序的权限与主机相同。

当前最新的安全机制实现，则引入了域 (Domain) 的概念，可以理解为将沙箱细分为多个具体的小沙箱。虚拟机会把所有代码加载到不同的系统域和应用域，系统域部分专门负责与关键资源进行交互，而各个应用域部分则通过系统域的部分代理来对各种需要的资源进行访问。虚拟机中不同的受保护域 (Protected Domain)，对应不一样的权限 (Permission)。存在于不同域中的类文件就具有了当前域的全部权限，如下图所示：



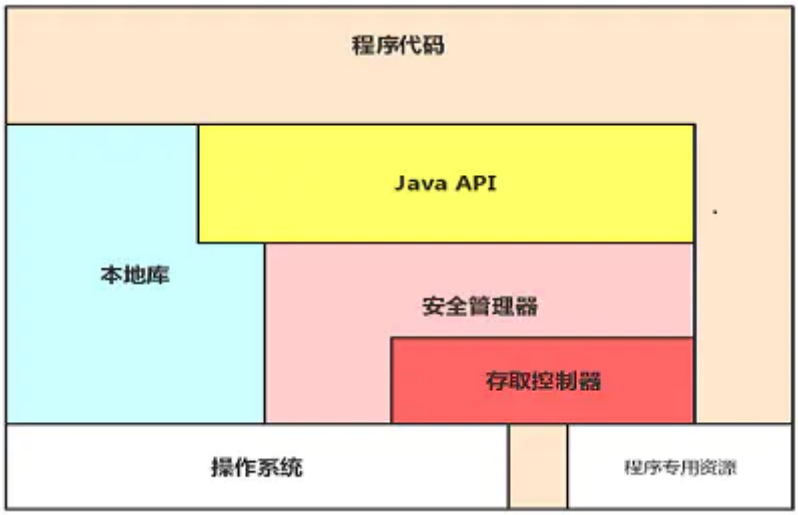
沙箱的实现取决于下面三方面的内容：

- 安全管理器，利用其提供的机制，可以使Java API确定与安全相关的操作是否允许执行。
- 存取控制器，安全管理器默认实现的基础。
- 类装载器，可以实现安全策略和类的封装。

从Java API的角度去看，应用程序的安全策略是由安全管理器去管理的。安全管理器决定应用是否可以执行某项操作。这些操作具体是否可以执行的依据，是看其能否对一些比较重要的系统资源进行访问，而这项验证由存取控制器进行管控。这么看来，存取控制器是安全管理器的基础实现，安全管理器能做的，存取控制器也可以做。那么问题来了，为什么还需要安全管理器？

首页 搜索掘金 登录 注册

> Java2以前是没有存取控制器的，那个时候安全管理器利用其内部逻辑决定应用的安全策略，若要调整安全策略，必须修改安全管理器本身。Java2开始，安全管理器将这些工作交由存取控制器，存取控制器可以利用策略文件灵活地指定安全策略，同时还提供了一个更简单的方法，实现了更细粒度地将特定权限授予特定的类。因此，Java2之前的程序都是利用安全管理器的接口实现系统安全的，这意味着安全管理器是不能修改的，那么引入的存取控制器并不完全替代安全管理器。两者的关系如下图：



二、 安全管理器

安全管理器是Java API和应用程序之间的“第三方权威机构”。好比贷款时，银行会根据央行征信系统查询用户的信用情况决定是否放款。Java应用程序请求Java API完成某个操作，Java API会向安全管理器询问是否可以执行，安全管理器若不希望执行该操作，会抛一个异常给Java API,否则Java API将完成操作并正常返回。

1.初识SecurityManager

SecurityManager类是Java API中一个相当关键的类，它为其他Java API提供相应的接口，使之可以检查某项操作能否执行，充当了安全管理器的角色。我们从下面的代码来看安全管理器是如何工作的?

```
public static void main(String[] args) {
    String s;
    try {
        FileReader fr = new FileReader(new File("E:\\test.txt"));
        BufferedReader br = new BufferedReader(fr);
```

首页 搜索掘金 登录 注册